



Kwema Ride

Platform Handbook

Haraka, salama na kwa wakati

Everything about how Kwema Ride works: what it is, how the money moves, why the technical decisions were made the way they were, what is built, what is not, and what has to happen before it carries a paying passenger.

A Jatelo Technologies product · Dar es Salaam, Tanzania

Version 1.0 · September 2026

Kwema Ride — Platform Handbook

Written for whoever needs to operate, extend, audit or hand over this system — including future you.

Contents

1. [What Kwema Ride is](#)
 2. [The market it is built for](#)
 3. [System overview](#)
 4. [The ride lifecycle, end to end](#)
 5. [Dispatch: how a driver is chosen](#)
 6. [Pricing and the fare engine](#)
 7. [Money: payments, commission and settlement](#)
 8. [Driver earnings and payouts](#)
 9. [Safety and SOS](#)
 10. [Identity, accounts and roles](#)
 11. [Driver onboarding](#)
 12. [Maps and routing](#)
 13. [Realtime layer](#)
 14. [Language and localisation](#)
 15. [The apps](#)
 16. [The website](#)
 17. [The admin panel](#)
 18. [Data model](#)
 19. [Security](#)
 20. [Regulation and compliance](#)
 21. [Deployment and environment](#)
 22. [Operating the platform](#)
 23. [What is not built](#)
 24. [Known issues and technical debt](#)
 25. [Before going live](#)
-

1. What Kwema Ride is

A ride-hailing platform for Tanzania covering four vehicle tiers: **bodaboda** (motorcycle), **bajaji** (three-wheeler), **standard car** and **XL**, with an **express** tier defined in the schema but not offered on the consumer surfaces.

Riders request a trip and see a firm price before committing. Drivers see their take-home before accepting. Payment is by mobile money, card or cash.

Motto: Haraka, salama na kwa wakati — *fast, secure and prompt.*

The product promise

The single differentiating claim is **the price you see is the price you pay**. This is not marketing framing; it is enforced in code:

- A quote is computed server-side, cached under a quote id, and locked for 180 seconds. The rider requests the ride *by quote id*, so a surge change between tapping and confirming cannot raise the price.
- On settlement, the final fare is capped at the quote plus a 20% tolerance. If a driver takes a much longer route, the rider does not silently absorb it; the trip is flagged for review instead.
- Distance and duration are computed from Google Directions on the server. An earlier version accepted them from the client, which meant a modified app could have quoted a 12 km trip as 2 km.

Haggling with a bodaboda rider at the roadside is the pain this removes.

Scale of the codebase

Part	Files	Lines
Backend (NestJS/TypeScript)	50	~8,100
Mobile (Flutter/Dart)	25	~6,100
Website + admin panel	8	~2,800
Database migrations	11	—

2. The market it is built for

Several decisions in this system only make sense against Tanzanian conditions. They are listed here because a future maintainer who does not know them will "fix" them into bugs.

Cash is not legacy

Cash remains the dominant rail, especially for boda and bajaji. This is why the driver wallet, cash-commission debt, and the dispatch cutoff for indebted drivers are core domain objects rather than an afterthought. A

platform that treats cash as an edge case ends up with drivers owing weeks of uncollected commission.

Connectivity is intermittent, not absent

Drivers lose signal for minutes at a time. Consequences throughout:

- Every device write is **idempotent** — a retry after a dropped acknowledgement returns the same ride rather than creating a second.
- The driver app buffers every GPS fix to local SQLite and deletes it only after the server acknowledges its sequence number.
- Socket.IO uses WebSocket first with **polling as fallback**, because some mobile proxies here still break the upgrade.
- An application-level heartbeat runs on top of Socket.IO's own ping, because a half-open TCP connection after a cell handover looks alive for minutes while dropping packets.

Bandwidth costs money

Location pings use one-character JSON keys and integer-scaled coordinates ($\times 1e6$). At one ping per driver every four seconds, the saved bytes are real money on a bundle-priced network.

Play Store access is inconsistent

Sideloaded APKs are a normal way to install an app here. The direct APK download therefore gets a first-class slot on the website alongside the App Store and Play buttons, not a hidden footnote.

English device locales mean nothing

Nearly every handset sold here ships with an English system locale regardless of what its owner speaks. So the apps **default to Swahili** and only honour a device locale when it is Swahili or French. Following the device would hand almost everyone an English app.

Emergency services are not dependable everywhere

Tanzania's national emergency number is **112**. It does not connect reliably outside the larger cities, and there is effectively no government ambulance service. The SOS feature is designed around this — see §9.

Shared connections are common

Cafés, driver hubs and carrier-grade NAT mean several genuine users can appear from one IP. Rate limits are tuned with this in mind: the driver application form allows 6 submissions per 10 minutes per IP rather than something tighter that would silently reject real applicants.

Change is given in 50-shilling steps

Fares round to the nearest 50 TZS, because that is the smallest note a driver can practically give change for on a cash trip.

3. System overview

Stack

Layer	Choice	Why
Mobile	Flutter	One codebase; consistent behaviour on the entry-level Android devices that dominate the driver fleet
Backend	NestJS (TypeScript)	Structured DI keeps a growing service legible; same language as the web surfaces
Database	PostgreSQL 16 + PostGIS 3.4	<code>GEOGRAPHY</code> gives true-metre <code>ST_DWithin</code> / <code>ST_Distance</code> with no projection juggling
Cache / geo	Redis 7	<code>GEOSEARCH</code> for dispatch, pub/sub for the Socket.IO adapter, distributed locks, surge tiles
Realtime	Socket.IO + Redis adapter	Automatic reconnection with backoff, and a polling fallback
Maps	Google Maps Platform	Better coverage of Dar's informal roads than the alternatives
Hosting	Railway	Single service runs API, website and admin panel

Everything runs from one service

The API, the marketing website, the web booking client and the admin panel are all served by the same Railway container. A separate static host would mean a second deploy target, cross-origin complications and another thing to keep in sync, for no benefit at this size.



Backend modules

Module	Responsibility
auth	Phone + OTP, token issue and rotation
users	Profile, display name, language preference
rides	Ride lifecycle, dispatch orchestration, ratings, breadcrumbs
dispatch	Driver matching and the offer loop
pricing	Fare quoting, settlement, surge
payments	Mobile money, card, cash settlement
earnings	Driver earnings, payouts, reconciliation
maps	Google proxy: routing, places, geocoding
realtime	Socket.IO gateway
safety	SOS alerts and emergency contacts
applications	Public driver sign-up
admin	Fleet, rides, tariffs, overview
health	Liveness, readiness, status page, public config
common	Redis wiring, scheduled jobs, WS throttling, env validation

4. The ride lifecycle, end to end



Status meanings

Status	Meaning
<code>requested</code>	Created, dispatch not yet started
<code>searching</code>	Being offered to drivers
<code>accepted</code>	A driver claimed it and is en route
<code>arrived</code>	Driver at the pickup point
<code>in_progress</code>	Trip underway
<code>completed</code>	Trip finished, fare settled
<code>cancelled_by_rider</code> / <code>cancelled_by_driver</code>	Cancelled
<code>expired</code>	No driver found after three passes
<code>failed</code>	Dispatch error

A unique partial index enforces **one active ride per rider** at a time.

5. Dispatch: how a driver is chosen

Sequential offers, not broadcast

Each candidate is locked in Redis with `SET NX` for the offer window and offered the ride alone for 15 seconds.

Broadcasting to everyone nearby gets faster acceptance and a much worse driver experience: four drivers accept, three lose, and acceptance-rate metrics become meaningless. The lock makes double-offer structurally impossible — the specific bug that erodes driver trust fastest.

Expanding rings

Search starts tight and widens. In Dar a 1.5 km first ring is dense enough at peak; in a Mwanza suburb the third ring does the work. Widening is cheaper than a bad first match.

Tier	Ring 1	Ring 2	Ring 3
boda	1,000 m	2,500 m	4,000 m
bajaji	1,200 m	3,000 m	5,000 m
standard	1,500 m	3,500 m	7,000 m
xl	2,500 m	5,000 m	9,000 m

Hard filters

A driver failing any of these is never offered the ride, however close:

- Not in `online_idle` state
- Last GPS ping older than 45 seconds (the device dropped off)
- Wallet debt past the ceiling
- **Statutory documents expired at this moment** — licence, insurance, LATRA
- Rider's minimum rating or helmet requirement not met

The compliance check is deliberately at dispatch time, not sign-on time. A driver whose insurance lapsed this morning stops receiving trips this morning.

Scoring

A composite score in $[0, 1]$:

Factor	Weight	Rationale
Proximity	50%	A rider cares far more about a 2-minute wait than a 4.9 vs 4.7 rating
Acceptance rate	20%	Rolling 24h
Rating	15%	Mapped from 1–5 stars, penalised by cancellation rate
Idle time	10%	Fairness — stops three drivers near a mall absorbing every trip
Completed trips	5%	Experience, with diminishing returns after ~500

ETA estimation

The top candidates get a real Distance Matrix call. Everyone else uses a straight-line estimate scaled by 1.35 to approximate road distance. A matrix call per candidate would blow both the latency budget and the maps bill.

PostGIS fallback

If Redis returns nothing across every ring — a cold start or a failover — dispatch falls back to a PostGIS KNN query before telling the rider there are no drivers.

6. Pricing and the fare engine

The calculation

```
base + (km × per_km) + (min × per_min) + waiting + zone surcharge
→ × surge (capped by the tariff's max_surge_multiplier)
→ floor at minimum_fare
→ + booking fee (basis points)
→ - promotion (funded by the operator, never the driver)
→ round to the nearest 50 TZS
```

Tariffs are versioned data, never constants

Rates live in the `tariffs` table with `valid_from` / `valid_to` and a `gazette_reference`. A rate change **closes the current row and inserts a new one** — it is never an `UPDATE`.

This matters because a fare charged last month must stay reproducible from the card that was in force when it was charged. That is what a LATRA audit or a rider dispute actually asks for. Overwriting a rate silently rewrites the history of every completed trip.

Zone-specific tariffs override national ones; the smallest matching service zone wins, so an airport polygon beats a city polygon.

Surge

Stepped, not continuous: **1.0 / 1.1 / 1.2 / 1.4 / 1.6**, driven by the demand-to-supply ratio in a geohash-6 tile (~1.2 km × 0.6 km), refreshed every 60 seconds.

Two reasons it is stepped. A smooth multiplier makes the displayed price flicker between taps. And under a regulated-fare regime, a wide, fast-moving multiplier is a compliance risk as much as a commercial one.

Below three open requests in a tile, surge stays at 1.0 — a single request in a quiet area must not produce a multiplier.

Settlement

The final fare uses the **actual driven distance**, measured with `ST_Length` over the ordered breadcrumb trail in PostGIS — never a figure the driver's device reports. A device that reports its own mileage is a device that can be modified to report more.

If the trace is too sparse (fewer than five points), it falls back to the quoted distance rather than producing a 200 TZS fare for a 12 km trip.

Commission

15%, set as a tariff version in migration 008. Charged on the transport fare only, excluding the booking fee and any pass-through zone surcharge.

VAT (18%, verify against the Finance Act in force) is computed on the operator's service fee, not on the driver's transport service.

7. Money: payments, commission and settlement

Three methods

Method	Who holds the money	Platform position
Cash	The driver, immediately	Platform is owed commission
Mobile money	The platform	Platform owes the driver their share
Card	The platform	Platform owes the driver their share

This is the single most important fact about the money model, and §8 explains its consequences.

Mobile money

Two aggregators behind one interface — **AzamPay** and **Selcom** — because one of them will be degraded on any given evening and being able to fail over is worth the extra adapter. Both front the same MNO rails: M-Pesa, Mixx by Yas, Airtel Money, HaloPesa.

Flow:

1. A **pending** transaction row is written **before** the aggregator is called. If the process dies mid-flight, reconciliation still finds the intent.
2. The aggregator pushes a USSD/STK prompt to the customer's handset.
3. The webhook confirms the outcome.
4. A reconciliation job sweeps anything stuck in **processing** after three minutes and asks the aggregator directly.

The webhook is the source of truth, never the HTTP response to step 1. Riders here routinely take 40+ seconds to find their PIN, so the synchronous call only tells you the push was accepted. A timeout leaves the transaction in **processing**, never **failed** — marking it failed invites a double charge.

Webhook protections: HMAC signature verified over the **raw request body** (re-serialising parsed JSON changes bytes and breaks the signature), a timestamp bound of five minutes on Selcom callbacks, idempotency via **SET NX**, a **SELECT ... FOR UPDATE** row lock, and an amount-match check. Signature-valid webhooks always return 200 even on business failure — a non-2xx makes aggregators retry for hours.

Cards

Via **DPO Pay**, which settles in TZS to a local bank account and handles 3-D Secure. Stripe does not operate here.

The card number never touches this server. The app opens DPO's hosted payment page in a browser; the customer enters their details under DPO's certificate; we verify with DPO directly afterwards. The redirect back is treated as a hint, not proof — the URL is user-controllable, so trusting it would let anyone mark a ride paid with a crafted link.

This keeps the platform in **PCI DSS SAQ-A**, the lightest bracket. Accepting card fields in our own UI, even just to forward them, would pull the whole platform into SAQ-D and an annual audit. Migration 004 adds a database constraint rejecting any receipt field long enough to hold a card number, as defence in depth.

Cash

Commission is booked when the **driver confirms collection**, not automatically on trip completion. A rider who leaves without paying is a real occurrence, and auto-booking would bill the driver for money they never received.

The debt ceiling is **proportional**, not flat: a base allowance plus headroom earned per completed trip, capped. A driver doing forty trips a day accrues commission far faster than one doing five, and a flat ceiling either strangles the busy driver or lets the casual one drift.

Past the ceiling, dispatch stops sending offers until they settle.

8. Driver earnings and payouts

The identity that governs everything

```
wallet_balance = total_driver_earnings - cash_the_driver_already_took
```

Verified against an independent derivation across simulated runs up to 500 trips, with zero discrepancy.

- **balance > 0** — the platform owes the driver. Include in the payout run.
- **balance < 0** — the driver owes the platform. Collect before the ceiling blocks them.

Why reporting gross earnings causes disputes

A driver sees "I earned 3,077,550" and does not account for the 2,044,500 already in their pocket from cash fares. The real payable was 1,033,050. Every earnings surface in this system shows the cash/digital split for exactly this reason.

Endpoints

Endpoint	Purpose
GET /api/drivers/me/earnings?period=today\ week\ month	Summary with the cash/digital split
GET /api/drivers/me/earnings/daily	Day-by-day, for the earnings chart
GET /api/drivers/me/statement?from=&to=	Every trip with its signed wallet effect
GET /api/admin/payouts	The payout run
GET /api/admin/debtors	Drivers carrying cash debt
POST /api/admin/payouts	Record a payout
GET /api/admin/reconcile?from=&to=	Rides versus money collected

Weeks run **Monday to Sunday in East Africa Time**. Days are local, not UTC: a driver finishing at 01:00 would otherwise see their night split across two days and dispute the figures.

The payout run has a 5,000 TZS minimum so you do not lose more in mobile money transfer fees than you send; the balance carries to the next run.

Reconciliation

Run this before every payout. It compares completed rides against money actually collected. A non-zero variance means a trip completed without its payment being accounted for — usually a cash trip the driver never confirmed. Paying out on top of that compounds the error.

Payouts record, they do not send

POST /api/admin/payouts moves the wallet balance in a locked transaction and writes a settlement row storing the balance **before and after**, so a disputed statement can be reconstructed exactly rather than re-derived from data that has since moved.

The actual money transfer is still manual. Automating it needs B2C disbursement credentials from AzamPay or Selcom.

9. Safety and SOS

The design constraint

112 is Tanzania's national emergency number, but it does not connect dependably outside the larger cities and there is effectively no government ambulance service. **An SOS that only dials 112 would fail exactly where a driver is most isolated.**

So each alert does three things at once:

1. Reaches Kwema operations with live position and full trip context — the route, the vehicle, both parties' numbers
2. Offers one-tap dialling of 112
3. Texts the person's **own emergency contact**

The third channel matters more here than it would in a country with dependable state services. That is why the contact fields sit on the user record and are prompted for rather than buried in settings.

Availability

Surface	When
Rider app	Always — home screen and during a ride
Driver app	Whenever online, plus during a trip
Web	Whenever signed in

The driver-when-idle case matters most: a driver parked online at 11pm waiting for a request is arguably more exposed than one mid-trip.

Interaction

Press and hold, not a confirmation dialog. A pocket cannot trigger it, and someone under stress does not have to read anything. The button fills as the hold progresses so the person can see it registered.

The alert is never lost

No missing GPS fix, absent trip, or database error prevents the alarm. A failed database write still emits to operations and logs loudly. Verified against PostGIS that an alert with no location is accepted and recorded.

The SOS endpoint has a deliberately generous rate limit. Someone pressing repeatedly is in trouble, not abusing the API, and a 429 there would be indefensible.

Operations

Admin sockets join an `ops` room and receive `sos:raised` instantly. The admin panel's SOS tab auto-refreshes every 10 seconds, sounds an alert on a new one, and offers map links plus one-tap dialling for both the person and their contact. Alerts are acknowledged, then resolved with a written outcome.

Alerts are never deleted. An alert record is evidence, and a resolved one is how the platform demonstrates it responded.

10. Identity, accounts and roles

One account, multiple roles

Riders, drivers and staff share one `users` row, so a driver can hail a ride without a second account. `roles` is a `user_role[]` array.

Phone + OTP

Passwords are optional; most riders will only ever use an SMS code.

- OTPs are stored **hashed**, single-use, five-minute expiry
- Five attempts maximum, then locked — a six-digit code is unguessable at that rate
- 60-second resend cooldown, which also stops the gateway being used to spam a number the attacker does not own

Tokens

Token	Lifetime	Storage
Access (JWT)	15 minutes	Platform keystore on mobile; <code>sessionStorage</code> on web
Refresh (opaque)	180 days	Platform keystore; not stored at all on web

Refresh tokens rotate on every use and are tracked in **families**. Presenting an already-rotated token means it was stolen, so the whole family is revoked rather than the single token.

Access tokens carry a `jti` checked against a Redis denylist on every request and every socket handshake, so a logout or ban takes effect immediately rather than at the next expiry.

Web sessions deliberately die with the tab. Internet cafés and shared PCs are a common way to get online here, and a token surviving the browser closing is account takeover.

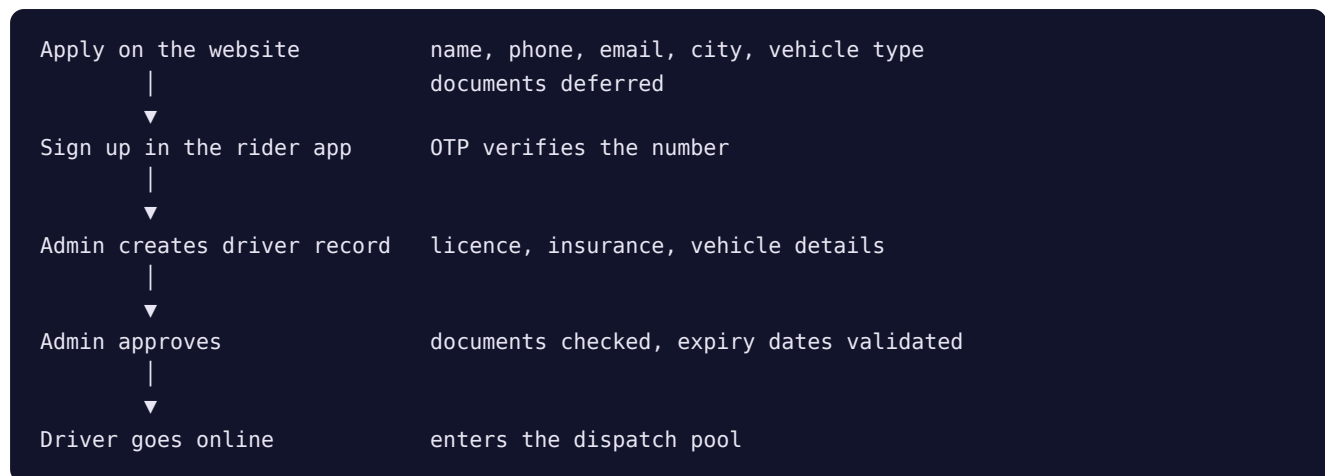
Roles in the token

Admin beats driver beats rider. Note the subtlety that caused a real bug: `node-postgres` parses built-in array types like `text[]` into JavaScript arrays, but has **no parser for an array of a custom enum**. `user_role[]` arrives as the raw string `"{rider,admin}"`. The `hasRole` helper handles both shapes.

Administrators

Granted from the `ADMIN_PHONE` environment variable at every boot, never seeded into a migration. A phone number committed to a public repository is a credential in version control, and revoking access should be a variable change rather than an edit to an applied migration.

11. Driver onboarding



Why the application is not a driver record

The public form is the only unauthenticated write on the platform. Writing straight into `drivers` would mean anyone with the URL could put a name into the fleet. An application is an unverified lead: the number is unproven, no documents exist, nobody has checked a licence.

Protections on that endpoint: a honeypot field that returns success while writing nothing (a bot gets no signal it was caught), strict validation, and rate limiting tuned for shared IPs.

Consent is required, not optional. Without it there is no lawful basis under Tanzania's Personal Data Protection Act to hold the record, so a missing tick means nothing is stored rather than stored-and-flagged.

Resubmission updates the existing application rather than duplicating it — people resubmit when a form does not visibly confirm.

Approval fails closed

`POST /api/admin/drivers/:id/verify` refuses if the driving licence is missing or expired, no vehicle is assigned, insurance has lapsed, or the LATRA licence has expired. This is the gate between an application and a vehicle carrying passengers under your operator licence.

12. Maps and routing

Everything is server-side

The mobile apps hold a bundle-restricted key that can only render map tiles. Directions, Distance Matrix, Geocoding and Places all go through the backend. Shipping a Directions-capable key in an APK means anyone who unpacks it can spend your Maps budget, and APKs get unpacked.

Three separate keys

Key	Restriction	Used by
Server	API restrictions only	Backend routing, Places, Geocoding
Browser	HTTP referrer	Website map display
Android	SHA-1 + package name	google_maps_flutter

Cost control

Google retired the universal \$200 monthly credit on 1 March 2025, replacing it with free monthly caps **per individual SKU** — roughly 10,000 requests each for Essentials-tier SKUs, with no shuffling between services. Directions and Distance Matrix bill per call, and riders re-quote constantly as they drag the pin.

Three mechanisms hold this down:

- Route results cached in Redis on a ~55 m coordinate grid
- Distance Matrix capped at five candidates per dispatch
- Places autocomplete uses session tokens, which Google bills per session rather than per keystroke

Requests outside a Tanzania bounding box are rejected before they cost anything.

Two failures worth knowing about

Places (New), not the legacy API. Projects created after Google's March 2025 legacy cutover cannot use the classic `place/autocomplete/json` endpoint — and it returns an **empty result set rather than an error**, so a misconfigured key looks identical to "no places matched". This cost several debugging rounds. `/api/maps/diagnostics` now calls every Google API and reports the real status.

Boda routing. Google has no bicycling coverage across most of East Africa, so requesting `mode=bicycling` for a bodaboda returned no results and every boda quote silently fell back to a straight-line estimate — on the highest-volume tier. It now retries in driving mode before giving up, then applies a 0.72 time factor because motorcycles genuinely do filter through stationary traffic.

13. Realtime layer

Socket.IO on namespace `/rt`, authenticated during the handshake so an unauthenticated socket never reaches a message handler.

Events

Client → **server:** `driver:location_update`, `ride:request`, `ride:accept`, `ride:decline`, `ride:status_change`, `hb`

Server → client: `session:ready`, `ride:status_change`, `ride:driver_moved`, `ride:request` (an offer), `ride:offer_closed`, `ride:fare_ready`, `payment:status`, `sos:raised`

Rooms

Room	Members
<code>user:{id}</code>	All of one person's devices
<code>ride:{id}</code>	Both parties on a trip
<code>driver:{id}</code>	One driver, for offers
<code>ops</code>	Administrators, for SOS

The Redis adapter is attached at the **root server** in `main.ts`, not in the gateway. A namespaced gateway receives a Socket.IO `Namespace` whose `adapter` is a property, not a method — calling it throws.

Reconnection

On connect, the server re-joins the socket to any in-flight ride rooms and sends a `session:ready` snapshot. The client does not re-subscribe; it just re-renders. This is what makes a reconnection after a tunnel seamless.

Sockets that go quiet past 60 seconds are reaped. Drivers get a 45-second grace period before leaving the geo pool, because a driver crossing a cell boundary reconnects within seconds and yanking them out would cost them the trip they were about to be offered.

Clock skew

The heartbeat acknowledgement carries server time. Handsets in the field are routinely minutes off, which would corrupt trip timestamps and make a driver's offer countdown wrong.

14. Language and localisation

Swahili default, English and French.

French earns its place: Tanzania borders Burundi, Rwanda and the DRC, there are established Congolese and Burundian communities in Dar and Kigoma, and francophone tourists are a real share of airport and Zanzibar ferry pickups.

Fallback order is active language → Swahili → English → the raw key. A Swahili speaker seeing one untranslated label is a smaller failure than a francophone seeing a mix of two foreign languages.

Vehicle tier names stay in their local form. A francophone in Dar asks for a "bajaji", not a "tuk-tuk"; translating the fleet vocabulary would make the app harder to use.

Currency

TZS has no circulating subunit. Never render "TSh 3,450.00" — it reads as broken. Symbol precedes the amount, comma thousands separator. Amounts are integer **cents** internally and divided only at the edge; the number format does not change with locale because Tanzanians write TZS the same way in all three languages.

Language is stored server-side too, because it decides what language OTP messages and notifications go out in — something the app cannot do for itself.

15. The apps

One Flutter project, two entry points sharing the core. Separate projects would guarantee the theme, localisation, API client and socket layer drift apart.

```
lib/
├─ main_rider.dart      rider entry point
├─ main_driver.dart     driver entry point
├─ core/
│   ├─ auth/            phone + OTP, token lifecycle
│   ├─ format/          TZS formatting
│   ├─ l10n/            three languages
│   ├─ location/        offline-first GPS buffer
│   ├─ models/          wire models, null-tolerant parsing
│   ├─ network/         Dio client, secure session store, Socket.IO
│   └─ theme/           tanzanite and marigold palette
└─ features/
    ├─ auth/            login, name capture
    ├─ rider/           home, quoting, live tracking
    ├─ driver/          dashboard, offer modal, trip lifecycle
    └─ shared/          activity, account, SOS, rating
```

Both apps have **Home, Activity and Account** navigation. `IndexedStack` keeps the map alive when switching tabs — rebuilding it would re-fetch tiles on a metered connection.

The offline location pipeline

Every GPS fix goes to local SQLite **first**, then to the socket. Rows are deleted only after the server acknowledges the sequence number. Cadence adapts to movement: a stationary driver drops to a 30 m filter with a 45-second keepalive floor. The buffer is bounded at 2,000 fixes and thins the oldest half by dropping alternate fixes, preserving route shape under long outages.

Without this, a two-minute dead zone on the Morogoro road puts holes in the trip trace — and the fare is computed from that trace.

The driver offer modal

The countdown is derived from the **server's absolute expiry**, not a local 15-second tick. A backgrounded app would otherwise show time remaining on an offer reassigned minutes ago.

Take-home is shown first and largest. Drivers look at it first, and showing gross while revealing the commission later is how a fleet is lost.

Accept latches on first press against double-tap. Losing the race is stated plainly rather than leaving a dead button on screen.

Design constraints

The driver is often on a motorcycle, sometimes in rain, wearing a helmet, glancing at the phone for under a second. Everything actionable is at least 56px tall and high contrast.

Vehicle tiers are identified by coloured bar rather than icon — riders with limited literacy recognise the tile by colour before reading it.

16. The website

Served from the same container at the root URL.

Path	What
/	Marketing site
/book.html	Web booking client
/admin.html	Admin panel
/status	Service status page

Design direction

The hero is a **fare board**, not a phone mockup. The product's value is a firm price before you travel, so the page opens with real Dar routes cycling through journey times. Structure borrows from transport wayfinding — boards, routes, waypoints — because that is this business's own vernacular.

Fare figures were deliberately removed from the marketing site: the tariffs are still provisional, and a marketing number that disagrees with the app's quote is worse than no number.

Typography is Bricolage Grotesque for display and DM Sans for body, the latter matching the apps so web and product read as one thing.

The logo

A **K** whose upper arm runs to a marigold waypoint — it reads as the initial and as a journey ending somewhere. Generated programmatically by `tool/generate_brand.py` rather than stored as exports, so the brand can be retuned in one place and the shapes stay exact at every size.

17. The admin panel

`/admin.html`, phone + OTP with an `admin` role. Seven sections:

Tab	What it does
Overview	Today's trips, gross, unserved-request rate, fleet status, money owed both directions, open SOS, new applications
SOS	Live emergency queue, auto-refreshing with an audible alert
Applications	Driver sign-ups from the website, with status workflow
Drivers	Fleet list, approve, suspend, create; filters for pending, online, in debt, documents expiring
Rides	Recent and active trips
Payouts	Who is owed, who owes, record a payout
Reconciliation	Rides versus money collected
Tariffs	Live rate cards, publish a new version

The **unserved-request rate** is the metric that matters most early on: every expired ride is a rider who wanted a trip and found no driver. Above 20% the panel says so explicitly, because supply is the constraint, not demand.

Publishing a tariff **requires a gazette reference** — a rate change must be traceable to the notice authorising it.

There is deliberately **no UI for granting admin**. That is the single most dangerous control in a panel like this; it lives in an environment variable.

18. Data model

Core tables

Table	Purpose
<code>users</code>	One identity for riders, drivers and staff
<code>drivers</code>	Driver profile, licences, state, wallet
<code>vehicles</code>	Vehicle, plate, insurance, inspection
<code>rides</code>	The trip, quote snapshot and settlement
<code>locations</code>	GPS breadcrumbs, partitioned by month
<code>transactions</code>	Money movement ledger, append-only
<code>ride_offers</code>	Dispatch audit trail
<code>tariffs</code>	Versioned rate cards
<code>service_zones</code>	Geofences for tariffs and surcharges
<code>surge_tiles</code>	Demand/supply per tile
<code>driver_settlements</code>	Payouts and debt collections
<code>driver_applications</code>	Public sign-ups
<code>sos_alerts</code>	Emergency alerts

Conventions

- **Money is `BIGINT` cents of TZS.** No floats. TZS has no subunit, but cents avoid rounding error and allow rates like 512.50 per km.
- **Positions are `GEOGRAPHY(Point, 4326)`,** so `ST_DWithin` and `ST_Distance` return true metres with no projection juggling.
- **Client-generated ids** on anything a device writes, for idempotent retries over flaky 3G.
- **Partial indexes** on hot paths — dispatchable drivers, open rides, unpaid rides, open SOS — so the index stays tiny.
- `locations` is **partitioned by month**, generated 24 months ahead at deploy time with a monthly cron extending it. A hardcoded partition means the first insert after that month silently fails, and since the fare depends on the breadcrumb trail, that is a billing outage.

Migrations

Plain SQL applied in filename order, tracked in `_migrations` with a checksum. Deliberately not TypeORM's migration system: this schema is mostly PostGIS features TypeORM does not model, and letting it generate migrations against them produces destructive diffs.

Each file runs inside a transaction. **Never edit an applied migration** — the runner warns and skips, leaving the database and the file disagreeing.

19. Security

Authentication and authorisation

Covered in §10. Beyond that:

- Ride events are scoped to `ride:{id}` rooms a socket may only join via a server-side membership check
- A driver accepting a ride must present a short-lived HMAC **offer token** issued with the offer, so a driver cannot claim a ride id they were never offered
- Every admin endpoint checks the role explicitly; there is no read-only tier that skips it

Rate limiting

Surface	Limit	Reasoning
Default	120/min	
OTP request	3/min	Each costs money and lands on a real handset
Payment initiation	5/min	Each pushes a USSD prompt to a real phone
Driver application	6/10min	Loosened for shared IPs and NAT
Maps proxy	30–40/min	Each call has a direct cash cost
SOS	30/min	Deliberately generous; a 429 here is indefensible
WebSocket	20/10s per socket	A looping GPS callback can take a node down

Secrets

Never on the device. The apps hold no aggregator credentials, no maps server key, no signing secret. Every third-party call is server-side.

Payload signing

Outbound aggregator requests are signed per provider — AzamPay bearer token plus API key, Selcom HMAC-SHA256 over an ordered canonical string. Inbound webhooks are verified over the raw body with

timing-safe comparison.

PII

NIDA numbers are encrypted at rest at the application layer. Breadcrumbs are partitioned by day and dropped after the retention window. Driver phone numbers are masked to riders.

Fraud controls worth building early

GPS mock detection on the driver app; trips whose driven distance diverges implausibly from the routed distance; accounts sharing a device fingerprint; cash trips completed with no plausible movement.

20. Regulation and compliance

LATRA

Tanzania's Land Transport Regulatory Authority regulates ride-hailing like transport, not like a marketplace. It sets guide fares per kilometre and per minute, a minimum fare, and ceilings on operator commission and booking fee.

Those ceilings have moved. A March 2022 order cut commission from around a third to 15%; a December 2022 gazette notice raised it to 25%. Uber withdrew from Tanzania in early 2026 citing the framework.

The engineering consequence: no rate, cap or fee is a constant anywhere in this codebase. All of them live in the versioned `tariffs` table with a gazette reference.

Kwema charges 15%, which is below the ceiling — the regulator sets a maximum, not a fixed rate.

Statutory documents

Held per driver and per vehicle, with expiry dates checked **at dispatch time**: driving licence, LATRA private-hire licence, PSV badge, police clearance, vehicle insurance, roadworthiness inspection.

Data protection

Tanzania's Personal Data Protection Act (2022) requires a lawful basis for holding personal data. The driver application form records consent with a timestamp and refuses to store anything without it.

TCRA

SMS sender IDs must be registered with the Tanzania Communications Regulatory Authority before messages will deliver.

Tax

VAT at 18% on the operator's service fee. Verify against the Finance Act in force.

21. Deployment and environment

Railway, three services

Service	Source	Note
kwema-ride-app	GitHub repo, Dockerfile	API, website, admin panel
PostGIS	postgis/postgis:16-3.4 Docker image	Not Railway's default Postgres
Redis	Railway plugin	

Railway's standard PostgreSQL plugin has no PostGIS, and migration 001 dies with `type "geography" does not exist`.

Deploy sequence

Docker build → `node dist/db/migrate.js` → environment validation → API binds to `0.0.0.0:$PORT`. A failed migration exits non-zero, so Railway keeps the previous deployment serving traffic.

Never set `PORT` — Railway injects it, and overriding it breaks the healthcheck.

Environment variables

Required: `DATABASE_URL`, `REDIS_URL`, `JWT_ACCESS_SECRET`.

Recommended: `OFFER_TOKEN_SECRET`, `ADMIN_PHONE`, `PUBLIC_BASE_URL`, `GOOGLE_MAPS_SERVER_KEY`, `GOOGLE_MAPS_BROWSER_KEY`, `SMS_API_URL`, `SMS_API_KEY`, `SMS_SENDER_ID`, `DATABASE_SSL`, `CORS_ORIGINS`, `WS_ALLOWED_ORIGINS`, `DEFAULT_AGGREGATOR`, the AzamPay/Selcom/DPO credentials, and the six app download URLs.

Startup validation refuses to boot on a missing, short or placeholder secret, naming the variable. A deploy that is misconfigured should fail loudly, not sign tokens with `undefined`.

Health

- `/health` — liveness, checks **nothing** deliberately. A dependency check here turns a brief Redis blip into a restart loop that makes the outage worse.
- `/api/health/ready` — Postgres, Redis and PostGIS individually.
- `/status` — human-readable status page.

Mobile builds

GitHub Actions builds both APKs and publishes them to a Release. No local Flutter toolchain needed. The `android/` folder is not committed — CI regenerates it, then patches the manifest and sets a distinct `applicationId` per app so both can coexist on one handset.

Buils are **debug-signed**: fine for direct download, rejected by the Play Store. A release keystore is needed for publishing.

22. Operating the platform

Daily

- Check the **SOS tab** — someone must be watching it
- Clear the **driver application** queue; every unanswered one is lost supply
- Watch the **unserved-request rate** on the Overview

Weekly

- Run **reconciliation** for the period
- Run the **payout run**, after reconciliation is clean
- Chase **drivers in debt** approaching their ceiling
- Check **documents expiring** in the Drivers tab

On a rate change

1. Obtain the LATRA notice
2. Publish a new tariff version in the admin panel with the gazette reference
3. Confirm the old card closed and exactly one live card exists per tier

Getting the OTP without an SMS gateway

Until `SMS_API_URL` is set, codes are written to the Railway deploy log. Filter for `OTP`. This is how you sign in for testing.

23. What is not built

Stated plainly so nobody assumes otherwise:

- **iOS builds.** The Flutter code would run on iOS, but CI builds APKs only and there is no Apple Developer account or signing set up.
- **Automated payouts.** Recording a payout moves the wallet; sending the money is manual.
- **Driver document upload.** Documents are collected offline; the admin enters the details.
- **In-app chat.** Riders and drivers call the masked number.
- **Scheduled rides, multi-stop trips, ride sharing, corporate accounts, promotions engine.**
- **Legal pages** — terms, privacy, cookies, insurance, community guidelines.

- **Push notifications.** The apps rely on the socket while open.
 - **Voice-proxy masking.** The mask is display-only; a real proxy needs a telephony provider.
 - **A rider-facing web account area** beyond booking.
-

24. Known issues and technical debt

Two migrations numbered 006. `006_clear_placeholder_names.sql` and `006_earnings.sql`. The runner sorts by filename so the order is deterministic and correct, but the collision is a trap — renumber before adding more.

APK size is ~53 MB. These are fat APKs carrying native code for every Android architecture. Split-per-ABI builds would get this to roughly 20 MB, which matters when users pay per megabyte.

No automated tests. Everything has been verified by running it — typechecks, boot tests, live API calls, real Postgres, browser automation — but there is no test suite guarding against regressions.

The Flutter code has never been run on a device by its author. It compiles in CI and the APKs install, but the build environment had no Flutter SDK, so runtime behaviour has only been checked by you.

Breadcrumb retention is unbounded. Partitions are created but never dropped. Add a retention job before the table becomes the biggest thing in the database.

Single replica. The architecture is replica-safe — ride rooms go through the Redis adapter, offer locks live in Redis — but the breadcrumb buffer and WebSocket throttle are per-node. Measure before scaling out.

`express` tier exists in the schema but is not offered in any app or on the website.

25. Before going live

Ordered by what blocks real money.

Must happen

1. **Replace the placeholder tariffs.** Every rate in `002_seed.sql` is marked `PLACEHOLDER`. Get the LATRA order in force and publish real cards with gazette references.
2. **Contract an SMS gateway** and register the sender ID with TCRA. Without it, nobody outside your Railway logs can sign in.
3. **Obtain aggregator credentials** — AzamPay or Selcom for mobile money, DPO for cards — and point the webhooks at the deployed URL.
4. **Decide who answers an SOS at 2am.** The alert reaches the panel instantly; it needs a human watching.
5. **Set real service-zone polygons.** The seeded ones are rough bounding boxes for Dar and JNIA.

6. **Publish legal pages** — terms, privacy, insurance, community guidelines — reviewed by an advocate, not drafted from a template.

Should happen

7. Restrict the webhook routes to the aggregator's published IP ranges.
8. Set `CORS_ORIGINS` and `WS_ALLOWED_ORIGINS` once the admin panel has a domain.
9. Generate a release keystore for Play Store publishing.
10. Add a breadcrumb retention job.
11. Set a Google Cloud budget cap and alerts.
12. Move to split-per-ABI APK builds.

Kwema Ride — a Jatelo Technologies product. Haraka, salama na kwa wakati.